THEORETICAL KNOWLEDGE:

1. Threat Hunting Methodologies:

Threat hunting:

Threat hunting means actively searching for hidden attackers inside a system or network before they cause major damage.
Incident response is reacting after an alert happens. Threat hunting is searching before or even when no alert exists.

For example instead of waiting for alert detecting account compromised , searching on logs to find unusual logins, strange admin activity, suspicious powershell commands, etc.

Proactive Threat Hunting:
This is when a SOC analyst or hunter actively investigates suspicious behaviour, even if there is no confirmed incident yet.

In proactive threat hunting no need to wait for SIEM alerts. In this thinks like
"What if an attacker is already inside, but tools didn't detect it?"

There are two main approaches:

- Hypothesis-Driven Hunting
- Reactive incident response

Hypothesis-Driven Hunting:

This is the best and most common hunting method. In this first create a hypothesis (an assumption), then test it using logs and evidence.

Example for hypothesis:

"An attacker may be misusing a valid user account to gain access."
Then investigates :

- Are there logins at unusual times
- Is one user logging in from multiple IPs
- Did a normal user suddenly become admin
- Did a service account start using SSH or PowerShell

Reactive incident response:

This is less proactive and starts after an alert

For example if SIEM shows 10 failed logins, suspicious admin login, powershell encoded command after that starts hunting to see did attacker move laterally, did they create persistence, did they access sensitive files, did they escalate privileges. This is still useful but it starts from an existing alert, not from own hunting hypothesis.

For example Hunt for anomalous privilege escalation in logs:

A threat hunter reviews system logs to detect unusual privilege escalation, such as a normal user suddenly using sudo, gaining administrator/root access, or being added to an admin group. This may indicate an attacker trying to gain higher privileges inside the system.

Hunting Frameworks:

Hunting frameworks are structured methods used by security analysts to perform threat hunting in a proper and organized way. Instead of randomly checking logs and alerts, a framework gives the hunter a step by step process to follow.

Frameworks:

1. SqRR
2. TaHiTI

SqRR Framework:

Full form of SqRR is Search, Query, Retrieve, Respond

This gives a logical sequence to follow while searching for threats.

1. Search : This is the first step where the hunter decides what suspicious behavior to look for.
   At this stage, the analyst identifies a possible threat or attack pattern that may be present in the environment.
   This step gives the hunt a clear direction. Without this step, hunting becomes random and ineffective

2. Query: Once know what to hunt for, write queries to search logs, SIEM data, or endpoint telemetry.
   For example, if hunting for suspicious account missuse then query can be used as below ,
   failed login attempts, successful logins after multiple failures, in windows event id 4625, event id 4624.

3. Retrieve:
   After running queries, collect and examine the relevant evidence. Retrieving useful information such as authentication logs, endpoint logs, firewall logs, network traffic, user account history,..etc.

   For example, if query shows a suspicious login at 1:00AM, then below information can be retrieved:
   Source ip, username, host name, login method, privilege usage after login.

4. Respond:
   If malicious activity is found, the final step is to take action. This response may include, isolate the affected host, disable the compromised account, block malicious IP, kill suspicious process, escalate to Incident Response team, create SIEM detection rule, update IOC lists, document the findings.

TaHiTI Framework:

Full form of TaHiTI is Targeted Hunting integrating Threat Intelligence. TaHiTI is a threat hunting framework that helps security analysts hunt for threats using Threat Intelligence. Instead of searching logs randomly, TaHiTI focuses on known attacker behaviour, TTPs, and threat reports to guide the hunt.

Main Steps of TaHiTI:

1. Gather Threat Intelligence:
   Collect information about attacker techniques, malware, or known threats.

2. Create Hunt Hypothesis:
   Build a hunting idea based on the threat intelligence.

3. Map to TTPs:
   Map attacker behaviour to MITRE ATT&CK techniques such as:
   T1078 – Valid Accounts
   T1068 – Privilege Escalation

4. Hunt in Internal Data:
   Search SIEM, endpoint, and network logs for related suspicious activity. Hunt in EDR logs, authentication logs, network traffic, SIEM data, firewall logs, endpoint telemetry.

5. Validate and Respond:
   If suspicious behaviour is found investigate further, contain the threat,

block malicious activity, create new detection rules

Data Sources for Hunting:

Data sources for threat hunting are the different types of logs and security information that analysts use to identify suspicious or malicious activity in a system or network.

Data Sources:

EDR Logs:

EDR (Endpoint Detection and Response) logs come from endpoints such as, laptops, desktops, servers, virtual machines. These logs record what is happening directly on the system.

Attackers often execute malicious activity on the endpoint first, such as launching malware, running scripts, creating new accounts, escalating privileges disabling security tools. This makes endpoint logs one of the most valuable hunting data sources

Network Traffic Logs:

Network traffic logs record communication between systems and devices. They help analysts understand who communicated with whom, when communication happened, which ports and protocols were used, whether traffic looks suspicious.

Network data is important because Attackers often need to

- contact command-and-control (C2) servers
- move laterally
- scan internal systems
- exfiltrate data
- maintain remote access

These actions often leave traces in network traffic.

Threat Intelligence Feeds:

Threat Intelligence (TI) feeds provide external information about known malicious activity.They include malicious IP addresses, malicious domains, malware hashes, attacker TTPs, phishing indicators, campaign details.

Threat intelligence helps hunters compare internal activity with known bad indicators and known attacker behavior. This makes hunting more focused and targeted.

Threat hunting relies on multiple data sources to detect hidden and suspicious activity across an environment. Important sources include EDR logs, which reveal endpoint behavior such as process execution and privilege escalation; network traffic, which helps identify command-and-control communication, lateral movement, and unusual outbound connections; and threat intelligence feeds, which provide

known malicious IPs, domains, hashes, and attacker TTPs. Additional sources such as authentication logs, SIEM data, and cloud logs further improve visibility. By correlating these diverse sources, analysts can perform more accurate and effective threat hunting.

Study SqRR and TaHiTI via SANS Threat Hunting papers:

SANS threat hunting papers explain that effective hunting should not be random. A good hunter should use a repeatable methodology, create hypotheses, use threat intelligence, and search across multiple data sources. SANS material consistently describes threat hunting as a proactive and iterative process rather than simple alert response.

SqRR is a structured threat hunting methodology that stands for Search, Query, Retrieve, and Respond. It helps analysts perform hunts in a systematic way by identifying suspicious activity, searching logs, collecting evidence, and taking action.

TaHiTI stands for Targeted Hunting integrating Threat Intelligence and focuses on using threat intelligence, attacker TTPs, and IOC data to guide proactive threat hunting. Together, these frameworks improve the effectiveness and accuracy of threat hunting operations.

Explore threat hunting case studies: APT29 via MITRE ATT&CK

APT29 is a well-known Advanced Persistent Threat (APT) group associated with stealthy cyber-espionage operations. It is a useful case study for threat hunting because the group often abuses legitimate credentials, uses built-in administrative tools, and moves quietly across systems to avoid detection. According to MITRE ATT&CK, common APT29 techniques include T1078 – Valid Accounts, T1059.001 – PowerShell, T1021 – Remote Services, and T1068 – Privilege Escalation.

In this case study, the hunting hypothesis is: “An attacker may be using stolen credentials to access internal systems and escalate privileges without triggering obvious malware alerts.” Based on this hypothesis, the SOC analyst searches for suspicious authentication and privilege activity across the environment.

The analyst reviews authentication logs for successful logins after repeated failures, logins outside normal working hours, and access from unusual IP addresses. They also examine privilege escalation indicators, such as unexpected sudo usage, a normal user being added to an admin group, or a standard account suddenly gaining root or administrator privileges. PowerShell and process logs are also checked for suspicious command execution, account discovery, or remote administration behaviour. These hunting steps align closely with ATT&CK-mapped behaviours documented for APT29.

During the hunt, one user account is found logging in late at night from a new IP address, using elevated privileges shortly after access, and connecting to multiple internal servers. This pattern suggests possible credential misuse and lateral movement. The analyst responds by disabling the account, isolating affected systems, reviewing additional logs, and creating detection rules to identify similar behaviour in the future.

This case study shows how MITRE ATT&CK techniques can guide proactive threat hunting to uncover stealthy attacker behaviour before it becomes a major incident.

Review Elastic's threat hunting guide for practical approaches:

Elastic's threat hunting guide provides practical methods for proactively finding hidden threats in an environment. It focuses on collecting and centralizing security data from sources such as endpoint logs, authentication logs, network traffic, and cloud systems. This helps analysts get a complete view of suspicious activity.

A key approach in Elastic is hypothesis-driven hunting, where the analyst makes an assumption, such as an attacker misusing a valid account, and then searches logs to confirm it. Elastic also supports query-based hunting, allowing analysts to search for unusual logins, suspicious commands, privilege escalation, lateral movement, and abnormal network connections.

In addition, Elastic uses machine learning, anomaly detection, dashboards, and threat intelligence feeds to identify hidden or uncommon behaviour. These features help analysts detect threats that may not trigger normal alerts.

Overall, Elastic's guide shows how to use data, queries, and behaviour analysis in a practical way to find threats early and improve security detection.

2.Advanced SOAR Automation:

SOAR Components:

SOAR stands for:

Security Orchestration, Automation, and Response

SOAR is a security solution that helps SOC teams handle alerts and incidents faster by connecting tools, automating repetitive tasks, and responding to threats in a structured way.

SOAR Components:
SOAR has three main components:

- Orchestration
- Automation
- Response

Orchestration:

Orchestration means connecting and coordinating multiple security tools and processes so they can work together in one workflow.

Automation:

Automation means using SOAR to perform repetitive tasks automatically without requiring the analyst to do them manually every time.

Response:

Response means the actual actions taken to contain, investigate, or stop a threat after it is detected.

Playbook Development:

A playbook is a step-by-step response plan used by SOAR to handle a specific type of security incident.
Playbooks help SOC teams:

- respond faster
- work in a standard way
- reduce mistakes
- automate incident handling
- improve consistency

Common Incident Playbooks
1. Phishing Playbook

A phishing playbook may:

- collect sender email and domain

- check reputation of links or attachments
- search if other users received the same email
- quarantine the email
- block the sender
- create a ticket for investigation

2. Malware Playbook

A malware playbook may:

- collect infected host details
- check file hash reputation
- isolate the endpoint
- kill suspicious processes
- notify the SOC team
- create an incident case

If a SIEM or IDS detects communication with a Command-and-Control (C2) IP, the playbook can:

- extract the malicious IP
- verify it using threat intelligence
- create an alert/ticket
- automatically block the IP in the firewall
- notify the analyst

This helps stop attacker communication quickly and improves response efficiency.

Integration with SIEM/EDR:

To integrate SOAR with Wazuh or Elastic, alerts generated by the SIEM are sent to the SOAR platform using webhooks, APIs, or connectors. Once the alert is received, SOAR automatically performs several actions such as enriching the alert with threat intelligence, creating incident tickets or cases, notifying security analysts, and triggering response actions. These response actions may include blocking malicious IP addresses, isolating compromised endpoints, or escalating the incident. This integration helps automate repetitive security tasks, reduces manual effort, improves response speed, and creates a streamlined and efficient workflow for handling security incidents in a SOC environment.

Study SOAR concepts via Splunk SOAR documentation:

According to Splunk SOAR documentation, SOAR stands for Security Orchestration, Automation, and Response. It is a platform used to automate security operations, connect different security tools, and improve incident response. Splunk describes SOAR as combining orchestration, playbook automation, and case management to help SOC teams respond faster and reduce manual work.

1)Orchestration

Orchestration means connecting multiple security and IT tools into one workflow. Splunk SOAR integrates with many third-party tools and apps so analysts can coordinate actions across SIEM, EDR, firewalls, identity tools, and threat intelligence platforms from one place.

2) Automation

Automation means reducing manual work by automatically performing repetitive tasks. Splunk SOAR uses playbooks to automate workflows such as IP reputation checks, phishing investigation, malware triage, user account actions, alert enrichment. Splunk documentation explains that playbooks can be built visually without much coding, which makes automation easier for analysts.

3) Response

Response means taking action when a threat is detected. Splunk SOAR can help respond by blocking malicious IPs, disabling user accounts, isolating endpoints, creating incident cases, notifying analysts. This helps reduce response time and improves consistency in incident handling.

4) Playbooks and Case Management

A key concept in Splunk SOAR is the use of playbooks, which are step-by-step workflows for handling incidents. It also includes case management, allowing teams to track investigations, assign tasks, and document actions in one place.

Review playbook examples in TheHive Project for incident response automation:

Reviewing playbook examples in TheHive Project shows how incident response can be automated using cases, observables, analyzers, and responders, often through integration with Cortex. Common playbooks include phishing investigation, malware analysis, brute-force detection, and C2 IP blocking. These playbooks automatically create cases, extract indicators such as IPs, hashes, or URLs, run threat intelligence or sandbox checks, and trigger actions like blocking IPs, isolating hosts, or notifying analysts. This automation helps SOC teams respond faster, reduce manual work, improve consistency, and make incident handling more efficient and organized.

Analyze automation case studies :

A common SOAR automation case study is phishing response automation. According to CISA phishing guidance, phishing is often used to steal credentials or deliver malware, so organizations should quickly identify and respond to suspicious emails.

In this case study, the workflow starts when a user reports a suspicious email or the email gateway detects one. The SOAR platform automatically creates an incident case, extracts important indicators such as the sender email, suspicious URL, attachment hash, and sender IP, and then checks them using threat intelligence tools like VirusTotal or OTX. If the indicators are confirmed malicious, SOAR can automatically quarantine the email, block the sender domain/IP, notify the SOC analyst, and create a ticket for investigation.

This automation reduces manual work, speeds up incident handling, and helps stop phishing attacks before they spread to more users. It also improves consistency because every phishing alert follows the same response process.

3. Post-Incident Analysis and Continuous Improvement:

Root Cause Analysis (RCA) is a method used to find the main reason why a cybersecurity incident happened. Instead of only fixing the visible issue, RCA helps identify the deeper cause so the same incident does not happen again.

For example, if a phishing attack succeeds, the problem is not only that the user clicked the email, but also that there may have been weak email filtering, lack of MFA, poor awareness training, or missing detection controls.

RCA Techniques:

1) 5 Whys Technique:

The 5 Whys is a simple RCA method where you keep asking “Why?” until you discover the actual cause of the incident. It helps analysts move from the surface problem to the real underlying weakness.

2) Fishbone Diagram:

The Fishbone Diagram is a visual RCA method used to list all possible causes of an incident under different categories. It helps teams identify multiple contributing factors instead of focusing on only one issue.

For example, RCA for a phishing breach revealing weak email filters:

In a phishing incident, the immediate cause may be that the user clicked a malicious email link and entered credentials. However, the root cause may be weak

email filtering, along with contributing issues such as lack of MFA, poor phishing awareness, and insufficient login monitoring.

RCA helps find the real reason behind a security incident so it can be prevented in the future.

Lessons Learned Process:

The Lessons Learned Process is the final stage of incident response where the team reviews what happened during a security incident and identifies ways to improve processes, tools, detection, response, and training.
Its purpose is not to blame people, but to help the organization become better prepared for future incidents.

Steps:

- Review the incident – Understand what happened during the security incident.
- Create a timeline – Record the sequence of important events from start to finish.
- Identify what worked well – Note the response actions that were effective.
- Identify what failed – Find the gaps, delays, or weaknesses in response.
- Find the root cause – Determine the main reason the incident occurred.
- Recommend improvements – Suggest better processes, tools, and training for the future.

Metrics and KPIs:

SOC Metrics and KPIs (Key Performance Indicators) are used to measure how well a Security Operations Center detects, investigates, and responds to security incidents.
They help teams understand:

- how fast threats are detected
- how quickly incidents are handled
- how effective the SOC is

Mean Time to Detect (MTTD):

MTTD measures the average time it takes for the SOC to detect a security incident after it has started.
Lower MTTD means faster threat detection
Mean Time to Respond (MTTR):

MTTR measures the average time it takes for the SOC to respond to and contain an incident after it has been detected.
Lower MTTR means faster incident response

Study RCA techniques via SANS Reading Room:

Studying Root Cause Analysis (RCA) through the SANS Institute Reading Room helps to understand how to identify the real cause of a cybersecurity incident instead of only fixing the visible problem. SANS incident-response guidance emphasizes learning from incidents by performing root cause analysis during eradication and recovery, so teams can prevent the same issue from happening again.

Common RCA Techniques

1. 5 Whys – Ask “Why?” repeatedly until the deeper cause of the incident is found.
2. Fishbone Diagram (Ishikawa Diagram) – A visual method to list possible causes under categories such as People, Process, Technology, and Policy.

Studying RCA techniques via the SANS Reading Room helps to learn how security professionals identify the true cause of cybersecurity incidents instead of only addressing visible symptoms. Focus on methods such as 5 Whys, Fishbone Diagram, which help uncover weaknesses in people, processes, and technology. These techniques are useful for understanding how incidents begin, how they spread, and what security gaps allowed them to happen. By learning RCA, analysts can improve investigations, strengthen defenses, reduce repeated incidents, and enhance incident response maturity. This helps organizations prevent similar attacks and improve overall cybersecurity readiness.

Review NIST SP 800-61 for post-incident activity guidelines:

NIST SP 800-61 Post-Incident Activity Guidelines:

1. Conduct a Lessons Learned Meeting
   After the incident is resolved, the team should review:
   - what happened,
   - how it happened,
   - how well the team responded,
   - what should be improved next time.
2. Create a Formal Incident Report
   Document the incident clearly, including:
   - timeline of events,
   - affected systems,
   - indicators of compromise (IOCs),
   - actions taken,
   - final outcome. This helps in future incidents and legal review if needed.

3. Preserve Evidence and Records
Keep logs, screenshots, alerts, memory captures, and other evidence securely according to the organization's retention policy. This is important for investigations, audits, and possible legal action.
4. Update Security Controls and Procedures
   Fix the weakness that caused the incident by improving:
   - detection rules,
   - firewall/IDS settings,
   - incident response playbooks,
   - policies and procedures.
5. Use Incident Data for Improvement
   Analyze collected incident data to identify:
   - recurring attack patterns,
   - common vulnerabilities,
   - response delays,
   - resource gaps.

Explore SOC metrics via CISA's Cybersecurity Metrics:

CISA's Cybersecurity Metrics show how well an organization can detect and respond to cyber threats. SOCs can use metrics like MTTD and MTTR to measure performance. Following these metrics helps improve security and respond to attacks faster.

MTTD – Mean Time to Detect:
The average time it takes for the SOC to notice a security threat after it starts. The faster a threat is detected, the less damage it can do.
For example, If a hacker breaks into a system at 10:00 AM and the SOC detects it at 12:00 PM, the detection time is 2 hours. MTTD averages this time over all incidents.

MTTR – Mean Time to Respond
The average time it takes for the SOC to respond and fix the threat after it's detected. Faster response reduces the impact of an attack and restores normal operations quickly.
For example, If the SOC detects a threat at 12:00 PM and blocks it by 2:00 PM, the response time is 2 hours. MTTR averages this for all incidents.

CISA's Cybersecurity Metrics provide measurable goals to track how well organizations detect and respond to cyber threats. SOCs can use metrics like MTTD

and MTTR to measure performance. Following these metrics helps improve threat detection, speed up response, and strengthen overall cybersecurity.

4. Adversary Emulation Techniques:

Adversary Emulation:

Simulating how real attackers operate by using their Tactics, Techniques, and Procedures. To test how well a SOC can detect, investigate, and respond to attacks.

T1566 – Phishing

- Attacker sends fraudulent emails to trick users into clicking malicious links or opening infected attachments.
- SOC test example, Send a controlled test phishing email to see if SOC detects suspicious sender, malicious URL, or attachment. Check alert generation, analyst investigation, and response workflow.

T1210 – Exploitation of Remote Services

- Attacker exploits vulnerabilities in services like RDP, SSH, SMB, or web applications to gain unauthorized access.
- SOC test example, Perform a safe simulated exploit on a test machine and verify whether SOC detects unusual login attempts, suspicious service access, or privilege escalation.

Emulation Frameworks:

MITRE CALDERA:

MITRE CALDERA is an open-source platform that automates red team testing.
It allows security teams to simulate attacker behaviour TTPs safely on their own network without causing real damage.
It uses the MITRE ATT&CK framework to model attacks and generate realistic scenarios.

Example – Spearphishing Simulation:
Goal is to Test email filtering and analyst response.
Steps in CALDERA:

- Launch a simulated spearphishing email to a test user account.
- Email contains a safe payload
- CALDERA tracks whether SOC tools detect the email as suspicious.
- SOC analysts respond, following their normal phishing incident workflow.

Outcome: Measures whether the email filter blocks phishing, if alerts trigger, and how effectively analysts respond.
MITRE CALDERA automates attacker simulations using MITRE ATT&CK TTPs. For example, it can safely send a spearphishing email to test email filters and SOC response, helping teams improve detection and incident handling.

Red-Blue Team Collaboration:
Red Team and Blue Team work together to improve an organization's security.
Red Team acts like an attacker and simulates real-world attack techniques.
Blue Team acts like the defender and monitors, detects, investigates, and responds to those attacks.
This collaboration helps the Blue Team understand how attackers behave in real situations and where the current defenses are weak.

adversary emulation informs defensive strategies:
When the Red Team performs adversary emulation, it shows:

- which attack methods are not being detected
- where logging and monitoring are missing
- which systems are poorly protected
- how quickly analysts can respond to alerts
- whether current incident response procedures actually work

This helps the Blue Team improve their defensive strategy by focusing on real attack paths instead of only theoretical threats.

it improves detection rules as:

- creating alerts for suspicious phishing activity
- improving detection for failed login bursts or brute force attempts
- tuning rules for remote service exploitation
- identifying abnormal PowerShell or command-line usage
- adding detections for lateral movement and privilege escalation
- reducing false positives and improving alert quality

Explore MITRE Caldera for emulation workflows and TTP mappings:
ITRE Caldera is an open-source adversary emulation tool that helps security teams simulate attacker behaviour using real-world ATT&CK techniques (TTPs). It is designed to automate red teaming, purple teaming, and detection validation by safely running attack steps in a lab or authorized environment. CALDERA is built around the MITRE ATT&CK framework, so each simulated action can be tied to a known attacker technique.
Basic workflow:

- Choose the adversary behaviour want to test
- Map it to ATT&CK TTPs
- Create or select an Adversary Profile
- Deploy an Agent
- Run an Operation
- Observe logs and alerts in the SOC
- Review results and improve detections

Working of TTP mappings in CALDERA:
CALDERA organizes attack actions as abilities. Each ability usually contains the command or action to run, the platform, required facts, the mapped ATT&CK technique id.
1.select ability
2.match it to ATT&CK TTP
3.execute the action
4.soc monitors detection

Study adversary emulation case studies:
APT28 is a well-known cyber threat group that has used phishing, stolen credentials, and remote access to attack organizations. In this adversary emulation case study, the goal is to safely copy APT28's attack behavior in a lab environment so the Security Operations Center can test its detection and response abilities.

The simulation begins with reconnaissance, where the attacker scans public-facing systems and gathers employee email addresses. Next, the attacker sends a spearphishing email with a fake login page or malicious link. If a user clicks it, the attacker captures login credentials and uses them to gain initial access.

After entering the system, the attacker creates persistence so access remains even after reboot. Then the attacker performs discovery to learn about users, devices, and network settings. In the next phase, the attacker steals credentials, moves to other machines using RDP or SMB, and collects important files such as documents and spreadsheets.

Finally, the attacker compresses the files and performs data exfiltration over web protocols like HTTP/HTTPS.

This MITRE ATT&CK-based emulation helps the SOC identify detection gaps, improve monitoring, and strengthen incident response against real-world APT28-style attack.

Review Red Canary's emulation guide for practical approaches:

1. Start with real threat intelligence: Choose a real attacker behaviour or threat that is relevant to organization.
2. Break the threat into ATT&CK techniques: Divide the attack into small steps using MITRE ATT&CK techniques.
3. Test one technique at a time: Run each technique separately in a safe lab to understand and validate it clearly.

4. Observe and validate detections: Check whether the SIEM, EDR, or SOC can detect and alert on the activity.
5. Improve detections after testing: Fix detection gaps, tune alert rules, and test again to strengthen defense.

5. Security Metrics and Executive Reporting:

Advanced SOC Metrics:

Dwell Time:

Dwell time is the time between when an attacker first compromises a system and when the SOC detects it.

Formula for that is:

Dwell Time = Detection Time – Compromise Time

For example:

If Attacker enters system at 2:00 AM and SOC detects activity at 10:00 AM then ,

Dwell Time is 8 hours

A high dwell time means attackers stay hidden for longer. A low dwell time means your SOC can detect threats quickly.

False Positive Rate:

his metric shows how many alerts were incorrectly flagged as malicious when they were actually harmless.

Formula for that is,

False Positive Rate = (False Alerts / Total Alerts) × 100

For example,

If total alerts in one day is 500 and false alert is 350 then false positive rate is 70%.

Tye goal of soc is Keep false positives low while still catching real attacks.

Incident Resolution Rate:

This shows how many security incidents were successfully handled and closed by the SOC.

Formula for this is,

Incident Resolution Rate = (Resolved Incidents / Total Incidents) × 100

For example,

If total incident in this month is 40 and resolved incident is 34 then incident resolution rate is 85%

The goal of soc is maintain a high resolution rate.

Executive Reporting:
To present metrics and incident summaries to non-technical stakeholders using clear visualizations and narratives:
For example, the analyst may show that the SOC handled 45 incidents this month, reduced average detection time from 6 hours to 2 hours, and resolved 90% of incidents successfully. A pie chart can show incident types like phishing, malware, and unauthorized access, while a bar graph can compare this month's performance with last month. They can explain in simple words that the security team is detecting threats faster, reducing risk, and improving response, which helps protect company data, systems, and business operations.
For example,
This month, our SOC handled 25 security incidents. Out of these, 22 were fully resolved, and the remaining 3 are under investigation. Our average detection time improved from 5 hours to 2 hours, which means we are identifying threats faster. We also reduced false alerts, helping analysts focus on real threats. No major business systems were affected, and no sensitive data was lost. Overall, the security team performed better this month compared to last month, showing improvement in both speed and response quality."

Continuous Improvement:
Continuous improvement means using SOC metrics to find weak areas and then fixing them step by step. It helps the Security Operations Center become faster, smarter, and more accurate over time.
For example, if MTTD is very high, it means team is taking too long to notice an attack. This may happen because of poor alert rules, too many false positives, lack of log visibility, or analysts missing important alerts. In this case, the solution could be to improve SIEM detection rules, tune alerts, add better log sources.
Proposed Solutions :

- Improve SIEM Detection Rules
- Add More Log Sources
- Reduce False Positives
- Use Threat Intelligence

Study SOC metrics via SANS Reading Room :
According to SANS Reading Room or SANS resources, SOC metrics are used to measure how well the SOC detects, investigates, and responds to threats, while also showing where improvements are needed. SANS emphasizes that good metrics should be tied to security goals and business impact, not just activity counts. Useful SOC metrics include MTTD , MTTR, false positive rate, alert volume, incident closure rate, dwell time, and escalation accuracy. These help measure detection speed, response efficiency, analyst workload, and overall SOC effectiveness. SANS

also recommends reviewing metrics regularly to identify gaps and improve SOC maturity over time.

Common SOC Metrics :

- MTTD : How quickly threats are detected
- MTTR : How quickly incidents are handled
- False Positive Rate : How many alerts are not real threats
- Alert Volume : Total alerts received
- Dwell Time : Time attacker stays undetected
- Incident Closure Rate : How many incidents are resolved
- Escalation Accuracy : How correctly analysts escalate incidents

Review CISA's Cybersecurity Metrics for reporting frameworks:
According to CISA, cybersecurity metrics should be used in a reporting framework to help to understand an organization's security posture, risk level, and improvement progress. CISA aligns many reporting practices with the NIST Cybersecurity Framework, which organizes reporting into Govern, Identify, Protect, Detect, Respond, and Recover. This helps teams report cybersecurity performance in a structured and meaningful way.
Frameworks Used for Reporting:

- CISA Cybersecurity Performance Goals (CPGs) : practical baseline security goals
- NIST Cybersecurity Framework (CSF) : Govern, Identify, Protect, Detect, Respond, Recover
- FISMA Reporting Metrics : used by federal agencies for cyber maturity and compliance reporting
- Risk-based reporting models : focus on outcomes, not only activity counts

Explore executive reporting templates via SANS Incident Response templates:

1. Incident Overview:
   in this include incident title, incident id, date and time detected, reported by, incident severity, current status

2. Executive Summary:
   A short overall summary of the incident.
   Write what happened, when it happened, who/what was affected, and current status.

3. Business impact:
   This explains how the incident affected the organization.

Write which users, systems, departments, money, work, or data were impacted.

4. Timeline of events:
   This is the step-by-step time order of the incident.
   Write what happened first, next, and last with time/date.

5. Root cause:
   This explains why the incident happened.
   Write the main reason or weakness that allowed the attack

6. Response action taken:
   This tells what the security team did after detecting the incident.
   Write the actions taken to stop, investigate, and fix the issue.

7. Current risk status:
   This shows whether the danger is still there or under control.
   Write if the incident is open, contained, resolved, or still risky.

8. Recommendation
   This gives suggestions to prevent the same incident again.
   Write what should be improved in tools, process, or training.

9. Lesson learned:
   This explains what the team learned from the incident.
   Write what worked well and what should be improved next time.